

Задание 1. Проанализировать DLP-события (25 баллов)

Ниже предоставлен примерный месячный отчет по выявленным инцидентам ИБ компании. События были выявлены средствами DLP, политики DLP составлены на основании внутреннего положения по информационной безопасности.

Необходимо:

1. определить наиболее рискованных пользователей;
2. выделить повторяющиеся нарушения;
3. определить основные каналы утечки;
4. предложить рекомендации.

Составить отчет в формате word. Отчет не большой на 2 – 4 страницы.

Общий отчет по инцидентам ИБ

Было выявлено 43 нарушений политики ИБ. Среди которых:

- 2 раз(а) Telegram: утечка данных по выручке. (1, 7)
- 1 раз(а) vk.com: утечка данных по выручке и марже. (2)
- 7 раз(а) Привилегированный сотрудник в активном поиске работы. (3, 4, 6, 29, 36, 37, 39)
- 2 раз(а) vk.com: утечка внутренних документов компании. (5, 42)
- 2 раз(а) Telegram: утечка логина/пароля от корпоративных ресурсов. (8, 35)
- 1 раз(а) Telegram: утечка данных по выручке и марже. (9)
- 1 раз(а) Иные типы инцидентов. (10)
- 4 раз(а) Слабые пароли. (11, 12, 13, 14)
- 1 раз(а) vk.com: утечка персональных данных сотрудников. (15)
- 2 раз(а) Telegram: утечка закупочных цен. (16, 19)
- 1 раз(а) Telegram: утечка данных по марже. (17)
- 4 раз(а) Установка/запуск вредоносного ПО. (18, 23, 26, 41)
- 1 раз(а) Копирование на USB-накопитель. (20)
- 3 раз(а) Сотрудник имеет кредит в МФО. (21, 22, 40)
- 1 раз(а) Отправка по email внешнему получателю. (24)
- 4 раз(а) Утечка КИ через ИИ. (25, 30, 34, 38)
- 1 раз(а) vk.com: утечка данных по товарному запасу. (27)
- 1 раз(а) Ведение личной предпринимательской деятельности. (28)
- 2 раз(а) Онлайн таблица в открытом доступе. (31, 32)
- 1 раз(а) Ставки на спорт. (33)
- 1 раз(а) vk.com: утечка персональных данных клиентов. (43)

Конкретные случаи:

1. **01.06 Сотрудник 1** (*Директор подразделения*) отправил через Telegram в чат «[Название чата 1]» таблицу «[Имя_файла_1].xlsx». В таблице содержится информация по выручке по месяцам на филиале. 2 участника, корпоративного бота контроля чатов нет (далее — «бота нет»).
2. **01.06 Сотрудник 2** (*Менеджер по сервису и обучению*) через VK в «Избранное» отправила снимок экрана, содержащий данные по выручке и марже (план/факт за месяц) по направлению.
3. **01.06 Сотрудник 3** (*Аналитик по коммерции / Департамент развития*) находится в активном поиске работы на сервисе [HH.ru].
4. **01.06 Сотрудник 4** (*Разработчик 1С / Департамент разработки*) находится в активном поиске работы, отправляет резюме в сторонние компании.
5. **01.06 Сотрудник 5** (*Бизнес-аналитик / Направление качества*) в «Избранное» VK выгрузил файл «[Имя_файла_2].pdf». В файле содержится коммерческая информация из внутренней системы «Описание процесса закупа и приемки медикаментов у 3PL-провайдера», 36 страниц.
6. **02.06 Сотрудник 6** (*Старший маркетинг-менеджер / Отдел маркетинга*) загрузила свое резюме в публичный ИИ-сервис [DeerSeek] и попросила написать сопроводительное письмо по вакансии в [Компания-конкурент 1].
7. **03.06 Сотрудник 7** (*Менеджер по сервису и обучению персонала*) отправила через Telegram в «Избранное» таблицу «[Имя_файла_3].xlsx». В таблице содержится информация по премиальной части линейного медперсонала за прошлый месяц, 56 строк.
8. **03.06 Сотрудник 8** (*Главный специалист по учету расходных материалов*) через Telegram в чат «[Название чата 2]» отправила таблицу «[Имя_файла_4].xlsx». В таблице содержатся актуальные логин и пароль от

учетной записи User_8 в Active Directory и корпоративном сервисе [Google Workspace]. 5 участников, бота нет.

9. **03.06 Сотрудник 9** (*Младший менеджер по ценообразованию услуг*) через Telegram отправила таблицу «[Имя_файла_5].xlsx». В таблице содержится информация по план/факт выручке за май (текущий/прошлый год), приросту к прошлому году, марже по категориям медицинских услуг (три листа: [Регион 1], [Регион 2], [Регион 3]). Получатель — «[Получатель 9]» (номера телефона нет, в AD есть сотрудник с идентичным ФИО — *Руководитель группы ценообразования и мониторинга рынка*).
10. **03.06 Сотрудник 10** (*Функциональный архитектор*) в личном облачном хранилище [Yandex Disk] под учетной записью «[УЗ_1]» хранит папку «![Название компании]» с подпапками: 1-[Проект_Лаборатория], 2-[Проект_Телемедицина], 3-[Поставки_Регион1], 4-[Поставки_Регион2], 5-[Направление_1], 6-[Направление_2], 7-[Cloud], 8-[Направление_3]. В папках содержатся таблицы и описание текущего функционала работы внутренних сервисов МИС (названия таблиц: «[Расчет_1]», «[Финансовая_разноска]»). Личный диск подключен через ПО yandexdisk2.exe.
11. **04.06 Сотрудник 11** (*Ведущий специалист отдела внутреннего контроля*) использует пароль от доменной учетной записи, не отвечающий требованиям ИБ. Второй фактор на почте установлен. Пароль: ![Строка_пароля_11].
12. **04.06 Сотрудник 12** (*Заместитель директора по безопасности / Клиника*) использует пароль от доменной учетной записи, не отвечающий требованиям ИБ. Второй фактор на почте установлен. Пароль: [Строка_пароля_12].
13. **04.06 Сотрудник 13** (*Специалист по учету медикаментов*) использует пароль от доменной учетной записи, не отвечающий требованиям ИБ. Второй фактор на почте установлен. Пароль: [Строка_пароля_13].
14. **05.06 Сотрудник 14** (*Ведущий специалист отдела внутреннего контроля / Клиника*) использует пароль от доменной учетной записи, не отвечающий

требованиям ИБ. Второй фактор на почте установлен. Пароль: [Строка_пароля_14].

15. **07.06 Сотрудник 15** (*Администратор регистратуры / Клиника*) через VK в «Избранное» отправила таблицу «[Имя_файла_6].xlsx». В таблице содержатся персональные данные (ПДн) сотрудников клиники (21 строка).
16. **08.06 Сотрудник 16** (*Менеджер по обеспечению препаратами*) отправила через Telegram в чат «[Название чата 3]» таблицу «[Имя_файла_7].xlsx». В таблице содержится информация по себестоимости медицинских препаратов и расходников (129 строк). 8 участников, права боту не переданы.
17. **08.06 Сотрудник 17** (*Главный врач филиала / Руководители*) через Telegram в чат «[Название чата 4]» отправила таблицу «[Имя_файла_8].xlsx». В таблице содержатся данные по маржинальности высокотехнологичных медицинских услуг (445 строк на трех листах). 4 участника, бота нет.
18. **08.06 Сотрудник 18** (*Менеджер отдела развития / Департамент развития*) на рабочем ПК установил запрещенное ПО (Torrent 3.5) и скачивал медиаконтент.
19. **09.06 Сотрудник 19** (*Менеджер по медицинскому маркетингу / Отдел маркетинга*) отправила через Telegram в чат «[Название чата 5]» таблицу «[Хэш_имя_файла].xlsx». В таблице представлена себестоимость медицинских исследований (6409 строк). 7 участников, бота нет.
20. **09.06 Сотрудник 20** (*Специалист технической поддержки / Группа ТП*) на внешний накопитель (USB\General_UDisk_Device_[ID]) скопировал папки с конфиденциальной информацией из сетевого ресурса \dfs\Share\..., включая ПДн пациентов (30 строк), сканы паспортов, счета на оплату услуг и медицинскую документацию за прошлые периоды.
21. **14.06 Сотрудник 21** (*Оператор call-центра / Административный персонал*) имеет просроченную задолженность в МФО 1 (сумма 22 544 руб.), а также

активные займы в МФО 2 (10 000 руб.) и МФО 3 (16 557 руб.). Задолженности закрывает. Активно интересуется спортом (чаты в мессенджере, сайты со статистикой игр). Негатива к компании нет.

22. **15.06 Сотрудник 22** (*Менеджер по страхованию и ДМС / Юридический департамент*) отправила заявку на кредит в МФО 4 (сумма 15 000 руб.), получила отказ. Негатива к компании нет.
23. **16.06 Сотрудник 23** (*Ведущий консультант ERP / Департамент разработки core-систем*) установил на корпоративное устройство нерегламентированное ПО VPN («[VanyaVpn]»).
24. **16.06 Сотрудник 24** (*Старший менеджер обучения / Отдел обучения call-центра*) на личный почтовый ящик [Личная_почта_1]@mail.ru отправила ссылку на презентацию в [Figma]. В презентации содержится регламент работы операторов с пациентами (находится в общем доступе).
25. **16.06 Сотрудник 25** (*Директор филиала / Руководители*) в публичный ИИ-сервис [DeerSeek] выгрузила таблицу «[Имя_файла_9].xlsx» (691 строка, столбцы: *Направление услуг, Маржа %, Выручка руб, Количество приемов (шт)*).
26. **17.06 Сотрудник 26** (*Системный администратор / Группа ТП*) скачал с внешнего ресурса [https://\[Сторонний_сайт\]](https://[Сторонний_сайт]) образ загрузочного диска на базе Windows PE. Проверка сайта сервис-анализатором вредоносного ПО угроз не выявила, однако сам образ перед записью просканирован не был. Образ скопирован на внешний накопитель (S/N: [СЕРИЙНЫЙ_НОМЕР]), факт использования в сети не зафиксирован.
27. **17.06 Сотрудник 12** (*Заместитель директора по безопасности / Руководитель ОВК клиники*) через VK отправил таблицу «[Имя_файла_10].xlsx» (1831 строка, столбцы: *Наименование услуги/препарата, Склад/Аптека, Физические остатки, Категория, Фин. сумма*). Получатель — «[Получатель 12]» (сотрудника с такой фамилией в компании нет).

28. **17.06 Сотрудник 28** (*Руководитель направления по корпоративной аналитике*) администрирует стороннее коммерческое сообщество в соцсети (магазин экипировки, 5600 подписчиков).
29. **17.06 Сотрудник 29** (*Старший менеджер по работе с партнерами и ДМС*) находится в активном поиске работы на сервисе [HH.ru].
30. **21.06 Сотрудник 30** (*Data-аналитик по ценообразованию*) загрузил в публичный ИИ-сервис [DeepSeek] таблицу «[Имя_файла_11].xlsx». В таблице содержится сводная информация по выручке, маржинальности и себестоимости медицинских услуг по всей сети клиник.
31. **22.06 Сотрудник 31** (*Ведущий специалист по взаимодействию с Минздравом и госорганами*) создал облачную таблицу «[Название таблицы]» в сервисе [Yandex] под личной учетной записью. В таблице содержится информация об официальных обращениях компании в контролирующие органы.
32. **22.06 Сотрудник 32** (*Специалист по работе с обращениями пациентов 1 категории / Чат-поддержка*) работала в общедоступной облачной таблице [Yandex] «[Имя_файла_12].xlsx». В таблице содержатся номера телефонов пациентов, даты и описания жалоб/обращений.
33. **22.06 Сотрудник 33** (*Ведущий специалист по охране / Клиника*) совершает ставки на спорт на букмекерском сайте [Fonbet] (размер ставки — 893 рубля на киберспорт).
34. **22.06 Сотрудник 34** (*Управляющий филиалом / Клиника*) в публичный ИИ-сервис [DeepSeek] отправила таблицу «[Имя_файла_13].xlsx» с промптом на анализ данных. Таблица содержит полные финансовые и операционные показатели медицинского центра за последние 2 года (выручка, план, выполнение, первичный/повторный трафик пациентов, средний чек, маржа, ФОТ врачей и др.).

35. **23.06 Сотрудник 35** (*Старший менеджер по работе с контрагентами*) хранит логины и пароли партнеров от корпоративных ресурсов в мессенджере Telegram в разделе «[Раздел]» / «[Избранное]» (1 участник, без ботов).
36. **23.06 Сотрудник 36** (*Руководитель отдела по найму*) проходила собеседование на позицию «Директор по подбору» в сторонний крупный холдинг через кадровое агентство.
37. **25.06 Сотрудник 37** (*Руководитель направления / Коммерческий отдел*) актуализировала резюме с помощью ИИ и общается в Telegram с карьерным консультантом («[Консультант]»). На текущей позиции работает со всеми коммерческими данными (выручка, маржа).
38. **25.06 Сотрудник 38** (*Бухгалтер по учету затрат / Бухгалтерия*) в публичный ИИ-сервис [DeerSeek] отправила документ «[UUID_документа].docx», содержащий оборотно-сальдовую ведомость по одному из юрлиц за прошлые периоды (дебет 10,8 млн руб.). После обработки загрузила его в личный кабинет вуза [УрГЭУ] как отчет по практике.
39. **25.06 Сотрудник 33** (*Ведущий специалист по охране*) откликнулся на вакансию «Начальник отдела безопасности» в сторонней компании [АО "Компания"]. Вел переписку с личной почты [Личная_почта_2]@mail.ru с адресом рекрутера [Рекрутер]@mytishchi.mosoblgaz.ru.
40. **26.06 Сотрудник 40** (*Оператор call-центра*) имеет просроченную задолженность в МФО 5 (41 490 руб.) и МФО 6 (39 322 руб.), а также активные займы по ранее зафиксированному инциденту INC-XXXX-XXXX.
41. **26.06 Сотрудник 41** (*Эксперт по работе с клиентами 3 категории / Отдел координации врачебных бригад*) использовал на рабочем ПК стороннее ПО-кликер (GSAutoClicker). Ранее уже привлекался по аналогичному инциденту INC-XXXX-XXXX.

42. **28.06 Сотрудник 42** (*Аккаунт-менеджер по работе с партнерскими лабораториями*) через соцсеть в «Избранное» отправила таблицу «[Имя_файла_14].xlsx». В таблице содержится 254 строки учетных данных авторизации (почта/пароль) к личному кабинету МИС.

43. **30.06 Сотрудник 43** (*Специалист по отменам и возвратам онлайн-записей*) через соцсеть в чат «[Название чата 6]» отправила таблицу «[Имя_файла_15].xlsx». В таблице содержатся ПДн и врачебная тайна пациентов (ФИО, телефон, e-mail, адрес, назначенные процедуры, 26 строк). В чате 5 участников.